Handbuch: Einrichtung der Microsoft Graph API (Outlook-Schnittstelle)

Projekt: KI-Telefonassistent & Smart-Routing (Storm GmbH)
Zweck: Automatisierter Lese-/Schreibzugriff auf Mitarbeiter-Kalender sowie automatische Erstellung von E-Mail-Entwürfen und Kundenbestätigungen in Microsoft 365.

---

1. Überblick & Funktionsweise

Die „Outlook API" heißt bei Microsoft offiziell **Microsoft Graph API**. Sie ist ohne Zusatzkosten in jedem geschäftlichen **Microsoft 365 Account** (bereits ab *Microsoft 365 Business Basic*) enthalten und wird über das **Microsoft Entra Admin Center** (ehemals Azure Active Directory) verwaltet.

Da der KI-Telefonassistent im Hintergrund auf einem Server arbeitet – ohne dass sich bei jedem Anruf ein Mitarbeiter manuell mit Passwort und Zwei-Faktor-Authentifizierung einloggen kann –, nutzen wir den sogenannten **App-Only-Zugriff (Client Credentials Flow)**.

---

2. Schritt-für-Schritt-Einrichtung (Dauer: ca. 5 Minuten)

Schritt 1: Im Portal einloggen & App registrieren

1. Öffne die Website **https://entra.microsoft.com** (alternativ: **https://portal.azure.com**) und melde dich mit einem Konto an, das Administratorrechte in Microsoft 365 besitzt.
2. Navigiere im linken Hauptmenü zu:
   Identität → **Anwendungen** → **App-Registrierungen** (*App registrations*).
3. Klicke in der oberen Aktionsleiste auf **+ Neue Registrierung** (*New registration*).
4. Vergib einen eindeutigen Namen, z. B.: `Storm-KI-Telefonassistent`.
5. Belasse den Punkt **Unterstützte Kontotypen** auf der ersten Standardoption:
   „Nur Konten in diesem Organisationsverzeichnis (Einzelner Mandant)".
6. Das Feld **Umleitungs-URI (optional)** bleibt leer (wird für Server-zu-Server-Kommunikation nicht benötigt).
7. Klicke unten auf den Button **Registrieren**.

Schritt 2: Anwendungs-ID und Mandanten-ID kopieren

Direkt nach der Registrierung öffnet sich die **Übersichtsseite (Overview)** der neu angelegten App. Kopiere dir dort die folgenden zwei Identifikationsnummern für deine spätere Konfiguration:

- **Anwendungs-ID (Client-ID)** → entspricht in der Konfiguration: `MICROSOFT_CLIENT_ID`
- **Verzeichnis-ID (Mandanten-ID / Tenant-ID)** → entspricht in der Konfiguration: `MICROSOFT_TENANT_ID`

Schritt 3: Geheimes Passwort (Client Secret) generieren

Damit sich dein KI-Server sicher gegenüber Microsoft ausweisen kann, wird ein geheimer API-Schlüssel benötigt:

1. Klicke im linken Menü deiner App-Ansicht auf **Zertifikate & Geheimnisse** (*Certificates & secrets*).
2. Wähle den Reiter **Geheime Clientschlüssel** und klicke auf **+ Neuer geheimer Clientschlüssel** (*New client secret*).
3. Trage eine kurze Beschreibung ein (z. B. `KI-Backend-Production`) und wähle die gewünschte Gültigkeitsdauer (z. B. *24 Monate*).
4. Klicke auf **Hinzufügen**.
5. **WICHTIGER SICHERHEITSHINWEIS:**
   Kopiere sofort die Zeichenfolge aus der Spalte **Wert (Value)** – **nicht** die „Geheime ID“! Sobald du diese Seite verlässt oder aktualisierst, wird der Wert von Microsoft aus Sicherheitsgründen unleserlich maskiert und kann nicht wiederhergestellt werden.
   → Dies ist dein `MICROSOFT_CLIENT_SECRET`.

Schritt 4: Outlook-Berechtigungen (Kalender & E-Mail) vergeben

Nun wird festgelegt, welche Aktionen die KI innerhalb von Microsoft 365 ausführen darf:

1. Klicke im linken Menü der App auf **API-Berechtigungen** (*API permissions*).
2. Klicke auf **+ Berechtigung hinzufügen** (*Add a permission*) und wähle das große Banner **Microsoft Graph**.
3. Wähle rechts die Box **Anwendungsberechtigungen** (*Application permissions*).
   (Hinweis: Nicht „Delegierte Berechtigungen“ auswählen, da die KI als Hintergrunddienst ohne angemeldeten Benutzer agiert).

4. Suche über das Suchfeld nacheinander die folgenden Berechtigungen heraus und setze jeweils das Häkchen:

Berechtigung	Zweck für den KI-Telefonassistenten
`Calendars.ReadWrite`	Prüft freie Zeitfenster der Mitarbeiter und trägt Rückruf- oder Besichtigungstermine direkt in deren Outlook-Kalender ein.
`Mail.ReadWrite`	Erstellt komplett vorformulierte E-Mail-Entwürfe (inkl. Kundendaten & Gesprächszusammenfassung) direkt im Ordner „Entwürfe“ des zuständigen Mitarbeiters.
`Mail.Send`	Versendet direkt nach dem Telefonat die automatische Eingangsbestätigung an den Kunden.
`User.Read.All`	*(Optional)* Ermöglicht das automatische Auslesen der vorhandenen Mitarbeiter-Postfächer zur Zuordnung im Dashboard.

5. Klicke unten auf den blauen Button **Berechtigungen hinzufügen**.
6. **Administratorzustimmung erteilen (Entscheidender Schritt):**
   Klicke nun oberhalb der Berechtigungstabelle auf die Schaltfläche **„Administratorzustimmung für [Firmenname] erteilen“** (*Grant admin consent for...*) und bestätige das Dialogfenster mit **Ja**.
   Prüfung: In der Spalte „Status“ muss nun bei allen Einträgen ein **grüner Haken** sichtbar sein.

---

3. Technische Einbindung in das KI-Projekt

Trage die drei kopierten Werte in die Umgebungsvariablen-Datei (`.env` bzw. `.env.local`) deiner Server-Anwendung ein:

```env
# Schaltet von der lokalen Simulation auf die echte Microsoft 365 Schnittstelle um
MOCK_MODE="false"

# Zugangsdaten aus dem Microsoft Entra Admin Center
MICROSOFT_TENANT_ID="hier-deine-verzeichnis-id-einfuegen"
```

```
MICROSOFT_CLIENT_ID="hier-deine-anwendungs-id-einfuegen"
MICROSOFT_CLIENT_SECRET="hier-deinen-geheimen-schluessel-wert-einfuege
n"
```
```

### Beispielhafte API-Endpunkte im laufenden Betrieb

Sobald die Zugangsdaten hinterlegt sind, steuert das Backend die jeweiligen Mitarbeiter-Konten direkt über deren E-Mail-Adresse (User Principal Name) an:

- **Kalendereintrag beim Techniker buchen:**
  `POST https://graph.microsoft.com/v1.0/users/techniker1@storm.gmbh/events`
- **E-Mail-Entwurf für den Innendienst anlegen (ohne sofortiges Absenden):**
  `POST https://graph.microsoft.com/v1.0/users/innendienst@storm.gmbh/messages`
- **Bestätigungsmail an den Anrufer senden:**
  `POST https://graph.microsoft.com/v1.0/users/info@storm.gmbh/sendMail`

---

## 4. IT-Sicherheit & Datenschutz (Argumentation für den Kunden / IT-Admin)

In mittelständischen Unternehmen (wie der Storm GmbH) stellt der interne oder externe IT-Administrator häufig eine wichtige Sicherheitsfrage:

> *„Wenn die KI die Berechtigung `Mail.ReadWrite` erhält, kann sie dann theoretisch auch die vertraulichen E-Mails der Geschäftsführung oder der Buchhaltung mitlesen?“*

### Die Lösung: Einschränkung per Application Access Policy

Microsoft bietet für genau diesen Fall eine offizielle Sicherheitsfunktion in **Exchange Online** an. Der IT-Administrator kann den Zugriff der KI auf eine fest definierte Gruppe von Postfächern (z. B. nur `disposition@storm.gmbh` und die 5 Außendienst-Kalender) beschränken. Alle anderen Postfächer (Geschäftsführung, Personalabteilung, Buchhaltung) sind für die KI technisch komplett gesperrt.
```

Der IT-Administrator des Kunden muss dazu lediglich drei kurze Befehle in der **Exchange Online PowerShell** ausführen:

1. **Sicherheitsgruppe in Microsoft 365 anlegen:**
   Eine Mail-aktivierte Sicherheitsgruppe erstellen (z. B. `ki-freigabe@storm.gmbh`) und nur die Mitarbeiter hinzufügen, mit denen die KI arbeiten soll.
2. **Zugriffsrichtlinie per PowerShell aktivieren:**

```powershell
New-ApplicationAccessPolicy `
  -AppId "HIER-DIE-MICROSOFT-CLIENT-ID-EINTRAGEN" `
  -PolicyScopeGroupId "ki-freigabe@storm.gmbh" `
  -AccessRight RestrictAccess `
  -Description "Beschraenkt den KI-Telefonassistenten ausschliesslich auf freigegebene Mitarbeiter-Postfaecher."
```

Damit sind sämtliche Compliance- und DSGVO-Anforderungen nach dem Prinzip der minimalen Rechtevergabe (*Least Privilege Principle*) zu 100 % erfüllt.

---

5. Optionen für deine eigene Test- und Demo-Umgebung

Um den Prototyp vor dem Kundentermin mit echtem Outlook zu testen, hast du zwei Möglichkeiten:

1. **Lokaler Simulations-Modus (`MOCK_MODE="true"`):**
   Bereits im Code integriert. Du benötigst kein Microsoft-Konto; alle Kalendereinträge und E-Mail-Entwürfe werden direkt im Dashboard auf deinem Bildschirm simuliert. Ideal für schnelle Vorführungen.
2. **Microsoft 365 Business Basic Test-Mandant (Empfohlen für Live-Demos):**
   Du kannst dir bei Microsoft eine **30-tägige kostenlose Testversion von Microsoft 365 Business Basic** (danach ca. 5,60 € / Monat) klicken. Darin legst du dir zwei Demo-Postfächer an (z. B. `notdienst@...` und `innendienst@...`) und kannst dem Geschäftsführer der Storm GmbH live auf dem Bildschirm zeigen, wie wenige Sekunden nach deinem Testanruf der Termin und der fertige E-Mail-Entwurf im echten Outlook aufploppen.